

MITRE ATT&CK

Gerçek dünyadaki siber saldırılarda saldırganların kullandığı davranış ve yöntemleri tanımlayan, kategorize eden ve ilişkilendiren bir bilgi tabanıdır. Güvenlik analistlerinin saldırıları anlamlandırmasına, logları incelemesine ve saldırgan davranışlarını belirli tekniklerle eşleştirmesine yardımcı olur.

Taktik (Tactic)

Taktik, saldırganın saldırı sırasında ulaşmak istediği amacı ifade eder. Yani “Saldırgan neyi başarmaya çalışıyor?” sorusunun cevabıdır.

- Sisteme ilk kez girmek → Initial Access
- Bir program/komut çalıştırmak → Execution
- Sistemde kalıcı olmak → Persistence
- Daha yüksek yetkilere ulaşmak → Privilege Escalation
- Güvenlik mekanizmalarından kaçmak → Defense Evasion
- Kimlik bilgilerini ele geçirmek → Credential Access
- Sistem hakkında bilgi toplamak → Discovery
- Başka sistemlere geçmek → Lateral Movement
- Veri toplamak → Collection
- Veriyi dışarı çıkarmak → Exfiltration
- Etki oluşturmak → Impact

Teknik (Technique)

Teknik, saldırganın belirli bir taktiğe ulaşmak için kullandığı yöntem veya davranıştır. “Saldırgan bunu nasıl yapıyor?” sorusuna cevap verir.

Örneğin, Brute Force (T1110) bir tekniktir. Saldırgan kimlik doğrulamasını aşmak amacıyla çok sayıda parola veya kimlik bilgisi deneyebilir.

Alt Teknik (Sub-technique)

Alt teknik, bir tekniğin daha spesifik bir yöntemini ifade eder. Örneğin T1110 Brute Force tekniğinin altında Password Guessing, Password Cracking ve Password Spraying gibi daha özel alt teknikler bulunur.

Matris (Matrix)

MITRE ATT&CK matrisi, saldırganların amaçlarını ifade eden taktikleri ve bu taktikler altında yer alan teknik ve alt teknikleri bir arada gösteren yapıdır. Analistlerin bir saldırı sırasında hangi davranışların gerçekleştiğini ve bunların saldırının hangi aşamasıyla ilişkili olduğunu görmesini sağlar.

Taktik	Örnek Teknik	Teknik ID
Initial Access (İlk Erişim)	Brute Force	T1110
Execution (Çalıştırma)	Command and Scripting Interpreter	T1059
Persistence (Kalıcılık)	Account Manipulation	T1098
Privilege Escalation (Yetki Yükseltme)	Exploitation for Privilege Escalation	T1068
Defense Evasion (Savunmadan Kaçınma)	Impair Defenses	T1562
Credential Access (Kimlik Bilgisi Erişimi)	OS Credential Dumping	T1003
Discovery (Keşif)	System Information Discovery	T1082
Lateral Movement (Yanal Hareket)	Remote Services	T1021
Collection (Veri Toplama)	Data from Local System	T1005
Exfiltration (Veri Çıkarma)	Exfiltration Over C2 Channel	T1041
Impact (Etki)	Data Destruction	T1485

Cyber Kill Chain ve MITRE ATT&CK Farkı

Cyber Kill Chain, saldırıyı genel ve sıralı aşamalar üzerinden açıklayan bir modeldir. Saldırının keşif, teslim etme, istismar ve komuta-kontrol gibi aşamalardan nasıl ilerlediğini gösterir.

MITRE ATT&CK ise saldırganın gerçekleştirdiği somut davranışları ve kullandığı teknikleri taktikler altında sınıflandırır.

Cyber Kill Chain saldırının genel akışını gösterirken, MITRE ATT&CK saldırganın kullandığı teknik ve davranışları daha ayrıntılı şekilde gösterir.

Kendi Çalışmalarımda MITRE ATT&CK Gözlemi

Gerçekleştirdiğim Olay	ATT&CK Taktik	Teknik / Alt Teknik	ID
Bir hesaba art arda başarısız giriş denemeleri yaptım.	Credential Access	Brute Force	T1110
Yeni bir yönetici hesabı oluşturdum.	Persistence / Privilege Escalation	Account Manipulation	T1098
sudo whoami ile root yetkisiyle komut çalıştırdım.	Privilege Escalation	Sudo and Sudo Caching	T1548.003
Windows'ta notepad.exe çalıştırarak Sysmon'da Process Create kaydı oluşturdum.	Execution ile ilişkili	Process Create kaydı	Sysmon Event ID 1

1. Başarısız giriş denemeleri – T1110 Brute Force

Ubuntu üzerinde aynı kullanıcı hesabına birden fazla başarısız SSH giriş denemesi yaptım. Bu denemeler /var/log/auth.log içerisinde Failed password kayıtları olarak görüldü.

Bu davranışı MITRE ATT&CK'teki Brute Force (T1110) tekniğiyle eşleştirdim. Brute Force, bir hesaba erişim sağlamak amacıyla farklı parola veya kimlik bilgilerini tekrar tekrar denemeyi ifade eder.

Örneğin log kaydı:

Failed password for vboxuser from 192.168.50.20

Bu nedenle:

- Taktik: Credential Access
- Teknik: Brute Force
- ID: T1110

Belirli bir alt teknik kullandığımı gösterecek yeterli kanıt olmadığı için T1110 seviyesinde bıraktım.

2. Yeni yönetici hesabı oluşturulması – T1098

Laboratuvar çalışmasında yeni bir kullanıcı hesabı oluşturdum ve bu hesabı Administrators'a ekledim. Bu davranış Account Manipulation (T1098) tekniğiyle ilişkilendirilebilir.

Account Manipulation, hesapların veya hesaplara ait yetkilerin değiştirilerek saldırganın sistem üzerindeki erişimini korumasını veya yetkilerini artırmasını ifade eder.

Bu nedenle:

- Taktik: Persistence / Privilege Escalation
- Teknik: Account Manipulation
- ID: T1098

Burada yeni hesabın yönetici yetkileriyle ilişkilendirilmesi, saldırganın sistemde erişimini devam ettirmesine ve daha yüksek yetkiler elde etmesine yardımcı olabilecek bir davranış olarak değerlendirilebilir.

3. sudo ile yetki yükseltme – T1548.003

Ubuntu üzerinde, sudo whoami komutunu çalıştırdım ve sonuç olarak root çıktısını aldım. Bu işlem normal kullanıcı yetkisinden daha yüksek bir yetki seviyesine geçildiğini gösterdi.

Bu davranış MITRE ATT&CK'teki Abuse Elevation Control Mechanism: Sudo and Sudo Caching (T1548.003) alt tekniğiyle eşleşmektedir.

- Taktik: Privilege Escalation
- Teknik: Abuse Elevation Control Mechanism
- Alt Teknik: Sudo and Sudo Caching
- ID: T1548.003

4. PowerShell üzerinden notepad.exe çalıştırılması – T1059.001

Windows üzerinde PowerShell kullanarak notepad.exe çalıştırdım. Bu işlem sonucunda Sysmon üzerinde Event ID 1 – Process Create kaydı oluştu.

Sysmon kaydındaki ParentImage, ParentProcessId ve CommandLine gibi alanlar incelenerek notepad.exe prosesinin PowerShell üzerinden başlatıldığı doğrulanabilir.

Bu nedenle olay, MITRE ATT&CK'teki Command and Scripting Interpreter: PowerShell (T1059.001) alt tekniğiyle eşleştirilebilir.

- Taktik: Execution
- Teknik: Command and Scripting Interpreter
- Alt Teknik: PowerShell
- ID: T1059.001
- Log kanıtı: Sysmon Event ID 1 – Process Create

Kimlik Doğrulama Protokolleri

Kerberos

Kerberos, özellikle Active Directory domain ortamlarında kullanılan bilet tabanlı bir kimlik doğrulama protokolüdür. Kullanıcı kimliğini doğruladıktan sonra KDC (Key Distribution Center) tarafından verilen TGT ve Service Ticket gibi biletlerle servislere erişir.

Kerberoasting: Saldırganın servis hesaplarına ait Kerberos biletlerini elde edip, servis hesabının parolasını offline olarak kırmaya çalıştığı saldırıdır.

NTLM

NTLM, Windows'ta kullanılan eski bir kimlik doğrulama yöntemidir. Kerberos gibi bilet kullanmaz, challenge-response mekanizmasıyla çalışır. Eski sistem ve uygulamalarla uyumluluk nedeniyle hâlâ karşımıza çıkabilir ve Kerberos'a göre daha zayıf kabul edilir.

Pass-the-Hash: Saldırganın gerçek parolayı bilmeden ele geçirdiği NTLM hash değerini kullanarak kimlik doğrulama yapmaya çalışmasıdır.

LDAP

LDAP, kullanıcı, grup ve bilgisayar gibi bilgilerin merkezi bir dizinde tutulmasını ve sorgulanmasını sağlayan bir protokoldür. Active Directory ortamında izin bilgilerine erişmek için kullanılır.

OWASP Nedir?

OWASP (Open Worldwide Application Security Project), uygulama güvenliği alanında çalışan, kâr amacı gütmeyen bir topluluk ve organizasyondur.

Web uygulamaları ve yazılımlardaki güvenlik riskleri hakkında araştırmalar, rehberler, araçlar ve güvenlik standartları sunar. Geliştiricilerin ve güvenlik uzmanlarının uygulamaları daha güvenli geliştirmesine yardımcı olur.

OWASP, sektörde özellikle OWASP Top 10 gibi güvenlik listeleriyle bilinir.